

MALWARE FAMILY INTELLIGENCE REPORT

Poison Ivy (PIVY)

Remote Access Trojan | Cyber-Espionage Toolkit | APT Weapon

Report Date: May 2026

1. Executive Summary

Poison Ivy (PIVY) is a long-standing Remote Access Trojan (RAT) first identified in 2005. Despite its age, it remains one of the most documented and persistently deployed malware families in the threat landscape, particularly favored by advanced persistent threat (APT) actors conducting cyber-espionage. Its point-and-click graphical builder, low barrier to entry, and reliable feature set have made it the instrument of choice for nation-state operators, cybercriminal groups, and hacktivists alike.

This report provides a comprehensive intelligence profile of Poison Ivy covering its discovery history, technical behaviour, infection chains, associated APT campaigns, IOCs, MITRE ATT&CK mapping, and detection recommendations — formatted per the RedKross Unified Threat Intelligence Platform standards.

2. Malware Family Overview

Family Name: Poison Ivy

Aliases / Other Names: PIVY, PoisonIvy RAT, Backdoor:W32/PoisonIvy, Backdoor.Poison

Malware Type: Remote Access Trojan (RAT) / Backdoor

First Observed: 2005 (publicly documented by security community)

Platform / OS Targeted: Microsoft Windows (all versions)

Primary Purpose: Cyber-espionage, remote surveillance, credential theft, data exfiltration

Current Status: Active (variants still in circulation as of 2026)

Attribution Confidence: Multiple distinct operator groups; one key cluster attributed to China-nexus actors

Key References: FireEye (2013) Poison Ivy Report; Proofpoint TA428 (2019); F-Secure; NJCCIC Advisory

3. Discovery History and Timeline

The following timeline captures the major milestones in the discovery and evolution of Poison Ivy:

Year / Period	Key Event
2005	Poison Ivy first publicly identified. The RAT builder (PIVY kit) becomes available, allowing attackers to generate customized server components with minimal technical skill.
2008 (Jan)	admin@338 campaign believed to start operations, using early PIVY passwords (key@123, gwx@123). Targeting financial, ISP/telco, government and defense sectors.
2009	Both th3bug and menuPass campaigns launch operations using PIVY. th3bug uses strategic web compromises (watering holes); menuPass uses spearphishing against defense contractors.
2011 (Mar)	RSA SecurID breach: PIVY used as post-compromise implant after Flash zero-day delivered via spearphishing email targeting RSA employees.
2011 (Nitro)	Nitro campaign uses PIVY against US government entities, chemical manufacturers, human rights organizations, and defense contractors.
2012	Java zero-day exploited to deliver PIVY payloads as part of extended Nitro campaign infrastructure.
2013 (Aug)	FireEye publishes landmark research — 'Poison Ivy: Assessing Damage and Extracting Intelligence' — analyzing 194 PIVY samples from 2008-2013. Releases Calamine detection toolset.
2013 (Jun-Jul)	Molerats (Gaza Hackers Team) adopt PIVY to attack Israeli government targets, signing payloads with a fake Microsoft certificate.
2013 (Aug)	PIVY exploited to infect visitors of a US government website via Internet Explorer zero-day.
2017 (Feb)	New PIVY campaign against Mongolian government detected; employs AppLocker bypass, fileless execution, Regsvr32-based payload delivery — updated techniques.
2019+	TA428 (China-nexus) uses PIVY in Operation LagTime IT against East Asian government agencies. C2 overlaps observed with Cotx RAT campaigns.
2020–2026	PIVY variants remain in circulation; continues to be documented in threat intelligence feeds. New campaigns observed leveraging PIVY alongside updated toolsets.

4. Technical Characteristics and Behaviour

4.1 Architecture and Builder

Poison Ivy is distributed as a crimeware kit consisting of a graphical builder (client) and a server component. The attacker installs the builder locally to generate customized server executables (the implant) which are then delivered to victim systems. Once installed, the server connects back to the attacker-controlled C2 listening on the builder machine. The kit uses a point-and-click interface, making it accessible to operators with limited technical skills.

4.2 Core Capabilities

- **Keylogging:** Records all keystrokes on the victim machine, capturing credentials and sensitive communications.
- **Screen Capture & Video Recording:** Takes screenshots and captures live video of the victim's desktop.

- Remote Shell Access: Provides interactive command-line access to the compromised system.
- File Manager: Full browsing, upload, download, and deletion of files on the victim's filesystem.
- Password Theft: Harvests saved passwords from browsers, email clients, and system credential stores.
- Process and Service Management: Lists, starts, kills processes and manages Windows services.
- Registry Editor: Reads and writes Windows registry, enabling persistence and configuration changes.
- Webcam and Microphone Access: Activates camera and microphone for covert surveillance.
- Traffic Relay: Routes attacker traffic through the victim host to pivot deeper into networks.
- Plugin Loading: Supports additional modules loaded at runtime to extend capability on demand.

4.3 Encryption and C2 Protocol

All communications between PIVY server (implant) and client (attacker's controller) are encrypted using the Camellia symmetric cipher with a 256-bit key. The encryption key is derived from a password configured by the attacker in the builder — the default value is 'admin'. The Camellia algorithm operates on 16-byte blocks. This encryption makes traffic analysis difficult without knowing the password. FireEye's Calamine tool can decode PIVY C2 traffic and memory artifacts when applied to captured sessions.

4.4 Injection and Evasion Techniques

- DLL Injection: PIVY injects its payload DLL into legitimate Windows processes (e.g., svchost.exe) to blend in with normal system activity and evade process-based detection.
- Anti-Disassembly: The injected code contains fake instructions and anti-analysis constructs that confuse disassemblers and slow reverse-engineering efforts.
- Anti-Debugging: Employs techniques to detect debuggers and analysis environments, including CheckRemoteDebuggerPresent checks.
- Alternate Data Streams (ADS): Some variants copy themselves to NTFS Alternate Data Streams to hide the file from standard directory listings.
- AppLocker Bypass: Newer campaigns (2017+) abuse Regsvr32.exe with remote SCT file loading to execute payloads while evading AppLocker controls.
- Fileless Persistence: Observed campaigns use fileless execution to reduce on-disk footprint and complicate forensic detection.
- Code Signing Abuse: Molerats campaign signed PIVY payload with a fraudulent Microsoft code-signing certificate to appear trusted.

4.5 Persistence Mechanisms

- Registry Run Keys: Adds entries to HKCU\Software\Microsoft\Windows\CurrentVersion\Run or equivalent HKLM path to ensure execution at every system boot. Key name and value are configurable in the builder.
- Startup Folder: May also copy itself to the Windows Startup folder for alternate persistence.
- Scheduled Tasks: Some variants create scheduled tasks as an additional persistence mechanism.

5. File Extensions and Packaging Formats

Poison Ivy servers are delivered through various packaging methods. The builder generates a server executable that attackers typically embed within legitimate-looking decoy files or use exploit-based delivery:

- Spearphishing attachments: Weaponized Microsoft Word (.doc, .docx) and PDF (.pdf) documents exploiting Office and reader vulnerabilities.
- ZIP archives: Compressed archives (.zip) containing weaponized documents, especially used in menuPass campaign.
- Executable disguised as legitimate software: PIVY server (.exe) may be named to mimic system files (e.g., svchost.exe, winlogon.exe).
- Script Components: Windows Script Component files (.sct) loaded via Regsvr32 in newer delivery techniques.
- DLL files: The injected component operates as a DLL loaded into legitimate processes; file name is attacker-defined.
- Alternate Data Streams: Server binary stored in NTFS ADS with no standard file extension visible in directory listings.

6. Known Hashes, Signatures, and YARA Rules

6.1 Known Sample Hashes

Type	Hash	Campaign / Context	Source
MD5	8010cae3e8431bb11ed6dc9acabb93b7	admin@338; C2: webserver.dynssl.com	FireEye 2013
MD5	0323de551aa10ca6221368c4a73732e6	gwx@123 campaign; C2: byinter.net	FireEye 2013
MD5	8002debc47e04d534b45f7bb7dfcab4d	C2: kr.iphone.qpoe.com; password: admin	FireEye 2013
MD5	55a3b2656ceac2ba6257b6e39f (partial)	menuPass campaign	FireEye 2013

6.2 YARA Detection Rules

FireEye released the Calamine toolset alongside their 2013 research, providing two components for PIVY detection:

- PIVY Callback-Decoding Tool (ChopShop module): Decodes encrypted network callbacks from PIVY-infected hosts, revealing the C2 communication stream. Available at github.com/fireeye/chopshop.
- PIVY Memory-Decoding Tool (PyCommand script): Extracts PIVY artifacts from live process memory, decrypting operator passwords, mutexes, and configuration data. Available at github.com/fireeye/pycommands.

Sample YARA rule structure for Poison Ivy detection (representative — operators should validate against current samples):

```
rule PoisonIvy_RAT {
  meta:
    description = "Detects Poison Ivy RAT (PIVY) memory artifacts"
    author = "FireEye / RedKross TI"
  strings:
    $camellia = "$camellia$"
    $mutex_pattern = {00 [1-20] 00 [1-20] 00 } // variable mutex
    $inject = "ws2_32" nocase
  condition:
    $camellia or ($inject and $mutex_pattern)
}
```

7. Associated APT Groups and Campaigns

Poison Ivy has been adopted by multiple distinct threat actor groups. FireEye's landmark 2013 analysis identified three primary APT campaign clusters through analysis of operator passwords and C2 infrastructure. Additional actors have since been documented using PIVY across geopolitical contexts:

7.1 admin@338

Active Since: January 2008 (earliest sample: December 27, 2009)

Suspected Nexus: China

Primary Targets: Finance, ISP/Telecom, Government, Defense

Primary Victims: USA, Taiwan, Hong Kong

Delivery Method: Spearphishing emails with weaponized document attachments (English language decoys)

C2 Passwords Observed: admin@338, key@123, gwx@123

Known Operators / Public References: No confirmed named individuals publicly attributed. Group identified by C2 password pattern 'admin@338'. Suspected state-sponsored China-nexus. Ref: FireEye (2013) Poison Ivy Report.

Related APT Groups / Overlaps: Infrastructure overlap suspected with other China-nexus groups targeting finance and government; no confirmed code-level overlap published.

7.2 th3bug

Active Since: October 2009

Suspected Nexus: China

Primary Targets: Higher Education, Healthcare

Delivery Method: Strategic web compromise (watering hole attacks); less targeted than admin@338

Notes: Stealthier and restrained in operational tempo compared to other PIVY groups

Known Operators / Public References: No confirmed named individuals publicly attributed. Group identified by C2 password 'th3bug'. Ref: FireEye (2013) Poison Ivy Report.

Related APT Groups / Overlaps: Tactical similarities with other China-nexus watering-hole operators; no confirmed shared infrastructure with admin@338 or menuPass.

7.3 menuPass (APT10 / Stone Panda)

Active Since: 2009

Suspected Nexus: China

Primary Targets: US and foreign defense contractors

Delivery Method: Spearphishing with zipped weaponized documents relevant to target

Notes: PIVY used as primary persistence mechanism; also associated with other RATs. Later evolved into broader MSP targeting.

Known Operators / Public References: US DOJ indictment (2018) named Zhu Hua and Zhang Shilong as operators of APT10 / menuPass (Stone Panda). Both alleged officers of China's Ministry of State Security (MSS), Tianjin Bureau. Ref: US v. Zhu Hua, Case No. 18-cr-891 (S.D.N.Y.).

Related APT Groups / Overlaps: APT10 / Stone Panda / POTASSIUM / Red Apollo. Overlaps in tooling and targeting with Cloud Hopper campaign (MSP targeting, 2016-2018). PIVY used alongside PlugX, RedLeaves, QuasarRAT.

7.4 Nitro Campaign

Activity Period: 2011

Primary Targets: US Government, chemical manufacturers, human rights groups, defense contractors

Delivery Method: Spearphishing; Java zero-day exploitation

Notes: One of the first high-profile campaigns to bring PIVY to widespread security community attention

Known Operators / Public References: No confirmed named individuals publicly attributed. Campaign documented by Symantec (2011) and FireEye. Suspected China-nexus based on targeting profile.

Related APT Groups / Overlaps: Overlapping victim sectors with admin@338; both target defense and government. Nitro infrastructure distinct but operator nexus suspected same region.

7.5 Molerats (Gaza Hackers Team)

Activity Period: June–July 2013

Suspected Nexus: Middle East (Palestinian-affiliated)

Primary Targets: Israeli government

Notes: Pivoted from XtremeRAT to PIVY; signed payload with fraudulent Microsoft certificate

Known Operators / Public References: No confirmed named individuals publicly attributed. Molerats / Gaza Hackers Team believed to operate on behalf of Palestinian political interests. Tracked by FireEye, ClearSky, Kaspersky. Ref: The Register (Aug 2013).

Related APT Groups / Overlaps: Overlaps with Gaza Cybergang, Moonlight, and Extreme Jackal. Shares targeting profile (Middle East governments) with other regional APT clusters.

7.6 TA428 (China-nexus, Operation LagTime IT)

Activity Period: Early 2019 – present

Suspected Nexus: China

Primary Targets: East Asian government IT, domestic affairs, foreign affairs, economic development

Delivery Method: Spearphishing; CVE-2018-0798 (Microsoft Equation Editor) exploit

Notes: PIVY payloads share C2 infrastructure with Cotx RAT; attributed by Proofpoint

Known Operators / Public References: No confirmed named individuals publicly attributed. TA428 tracked by Proofpoint; linked to Chinese state-sponsored activity. Ref: Proofpoint (2019) — 'Operation LagTime IT'.

Related APT Groups / Overlaps: C2 infrastructure overlaps with Cotx RAT campaigns (TA428 custom tool). Targeting profile overlaps with APT41 and other China-nexus groups active in East Asian government sectors.

8. Campaign Tracking

The following table summarizes documented Poison Ivy campaigns across their activity periods, victim geographies, target sectors, observed TTPs, and IOC summaries:

Campaign ID	Threat Actor	Activity Period (UTC)	Victim Countries	Target Industries	TTPs	IOC Summary
CAMP-PI-001	admin@338	Jan 2008 – 2013+	USA, Taiwan, Hong Kong	Finance, ISP/Telco, Government, Defense	T1566, T1059, T1219, T1055	IPs: 219.76.208.163; Domains: webserver.dynssl.com, webserver.freetcp.com
CAMP-PI-002	th3bug	Oct 2009 – 2013+	USA, Global	Higher Education, Healthcare	T1189, T1219, T1082	Waterholes; 147 domains across campaign; 165 IPs mapped
CAMP-PI-003	menuPass (APT10)	2009 – 2013+	USA, Japan, EU	Defense Contractors	T1566, T1027, T1219, T1078	Domains: byinter.net subdomains; zipped weaponized docs
CAMP-PI-004	Nitro Campaign	2011	USA, UK, EU, Asia	Govt, Chemical Mfg, NGOs, Defense	T1189, T1566, T1219	Java zero-day CVE-2012-xxxx; PIVY server delivered via spearphish
CAMP-PI-005	RSA SecurID Attack	2011	USA	Defense/Security Industry	T1566, T1055, T1219	Spearphish with Flash zero-day; PIVY used post-compromise
CAMP-PI-006	Molerats (Gaza Hackers)	Jun–Jul 2013	Israel	Government	T1566, T1219, T1553	Signed with fake Microsoft cert; pivoted from XtremeRAT
CAMP-PI-007	TA428 (China)	Early 2019+	Mongolia, East Asia	Govt IT, Foreign Affairs, Economic	T1566, T1055, T1219	CVE-2018-0798 Equation Editor; C2 overlaps with Cotx RAT campaign

9. IOC Knowledge Base

The following table documents confirmed IOCs associated with Poison Ivy campaigns. Researchers should enrich these against live threat intelligence feeds and passive DNS for current resolutions:

IOC Type	Value / Example	Context / Notes	Confidence
File Hash (MD5)	8010cae3e8431bb11ed6dc9acabb93b7	admin@338 PIVY sample; C2: webserver.dynssl.com	High
File Hash (MD5)	0323de551aa10ca6221368c4a73732e6	gwx@123 campaign; C2: byinter.net subdomains	High
File Hash (MD5)	8002debc47e04d534b45f7bb7dfcab4d	C2: kr.iphone.qpoe.com; password: admin	High
File Hash (MD5)	55a3b2656ceac2ba6257b6e39f (partial)	menuPass campaign sample	Medium
IP Address	219.76.208.163	admin@338 C2; resolves via dynssl.com / freetcp.com	High
Domain	www.webserver.dynssl.com	admin@338 C2 domain	High
Domain	www.webserver.freetcp.com	admin@338 C2 domain	High
Domain	www.webserver.fartit.com	admin@338 C2 domain	High
Domain	microsofta/b/c/e.byinter.net	gwx@123 campaign C2 (Microsoft impersonation)	High
Domain	kr.iphone.qpoe.com	PIVY sample C2 domain	Medium
Mutex	Variable (148 unique mutexes found)	Attacker-defined; used for single-instance checks	High
Password/Key	admin, admin@338, th3bug, menuPass	C2 access passwords; Camellia key derivation source	High
User Agent	Custom / spoofed browser UA	HTTP C2 traffic uses spoofed user-agent strings	Medium
Certificate	Fake Microsoft code-signing cert	Used in Molerats campaign (2013)	High

10. TTPs and MITRE ATT&CK Mapping

Poison Ivy maps comprehensively across the MITRE ATT&CK Enterprise framework. The following techniques have been documented across PIVY campaigns:

Tactic	Technique ID	Technique Name	Notes
Initial Access	T1566.001	Phishing: Spearphishing Attachment	Primary vector; weaponized Word/PDF docs
Initial Access	T1189	Drive-By Compromise	Used by th3bug via strategic web compromise

Tactic	Technique ID	Technique Name	Notes
Execution	T1059	Command and Scripting Interpreter	Executes via cmd, regsvr32, SCT files
Execution	T1203	Exploitation for Client Execution	IE zero-day (2013), Java zero-day (2012), CVE-2018-0798
Persistence	T1547.001	Registry Run Keys / Startup Folder	Registry modifications for autostart on boot
Defense Evasion	T1055	Process Injection	DLL injection into host processes
Defense Evasion	T1027	Obfuscated Files or Information	Anti-disassembly; fake instructions in code
Defense Evasion	T1553.002	Code Signing	Fake Microsoft cert (Molerats campaign)
Discovery	T1082	System Information Discovery	Collects OS, hostname, process info on infection
Discovery	T1057	Process Discovery	Enumerates running processes
Collection	T1056.001	Keylogging	Core PIVY capability; keystrokes captured continuously
Collection	T1113	Screen Capture	Screenshot and video capture capability
Collection	T1005	Data from Local System	File browsing and exfiltration
Command & Control	T1219	Remote Access Software	Full remote control via C2 operator interaction
Command & Control	T1071.001	Application Layer Protocol: Web Protocols	HTTP/HTTPS C2 communications
Exfiltration	T1041	Exfiltration Over C2 Channel	Data exfil over existing encrypted C2 connection
Credential Access	T1003	OS Credential Dumping	Password theft capability built into PIVY

11. Infrastructure Notes

11.1 C2 Communication

- Poison Ivy uses TCP-based communication to a configurable port (default 3460) with all traffic encrypted using Camellia-256. The key is derived from the operator-set password.
- C2 domains frequently use dynamic DNS services (dynssl.com, freetcp.com, fartit.com, byinter.net, qpoe.com) to facilitate rapid IP rotation and evade static IP blacklisting.

- The admin@338 group was observed using domains resolving to 219.76.208.163, suggesting a shared hosting or bulletproof hosting arrangement.
- FireEye's analysis mapped 147 unique C2 domains and 165 unique IP addresses across 194 PIVY samples.

11.2 Hosting and ASN

- C2 infrastructure observed primarily on hosting providers in Asia and Eastern Europe with lax abuse reporting policies.
- Some PIVY operators proxy C2 traffic through a relay server using port forwarding to conceal the true C2 IP — APT1 analysis documented PIVY daemons hidden behind proxy infrastructure.
- In at least one case, investigators found the PIVY operator's C2 running on VMWare-based infrastructure, identified via MAC address OUI analysis.

11.3 Cleanup Behaviour

- PIVY does not implement automatic cleanup of dropped files; artifacts may persist post-infection.
- Variants using ADS storage may leave hidden data streams on filesystem even after primary executable deletion.
- Registry persistence keys remain unless explicitly removed; incident responders should enumerate Run keys and startup entries during remediation.

12. Unique File System and Artifact Patterns

- Registry autorun entry under HKCU\Software\Microsoft\Windows\CurrentVersion\Run with attacker-defined value name — may mimic legitimate software names.
- DLL files injected into svchost.exe or other system processes; no canonical filename — investigator should look for unsigned or anomalously loaded DLLs in system process memory.
- NTFS Alternate Data Stream (ADS): PIVY may write its server binary into an ADS on an existing file. Forensic tools (e.g., Streams.exe, Autopsy) required to enumerate ADS.
- Network socket on non-standard port (configurable; default 3460) with encrypted Camellia traffic; detectable via NetStat or EDR network telemetry.
- Mutex artifacts in process memory: 148 unique mutexes documented across 194 samples; mutex name is operator-configurable but consistent within a campaign group.
- Anti-disassembly artifacts: code contains deliberate 'fake' instruction sequences to impede static analysis; dynamic analysis in sandbox recommended.

13. Detection and Response

The following detection signatures, behavioural rules, and response guidance are recommended for organizations protecting against Poison Ivy:

Detection Type	Rule / Indicator	Notes
YARA (Network)	Camellia 256-bit encrypted C2 traffic pattern	Calamine ChopShop module decodes PIVY callbacks

Detection Type	Rule / Indicator	Notes
YARA (Memory)	PIVY injected code fragment signature	PyCommand script extracts from memory; detects in-process payload
Registry	HKCU\Software\Microsoft\Windows\CurrentVersion\Run	Persistence key; value name varies by builder config
File Artifact	ADS (Alternate Data Stream) write to NTFS	Some variants hide payload in ADS; detected via ADS scanning tools
Network	Outbound TCP to attacker-defined port (default 3460)	Custom port set in PIVY builder; watch for unusual outbound connections
Network	Camellia-encrypted beacon pattern	Key derived from operator password; Calamine tool decodes it
Process	svchost.exe with unusual parent / injected DLL	PIVY injects into svchost or other Windows processes
Sigma	T1055 Process Injection + T1547.001 Reg Run Keys	Combine EDR telemetry for correlation rule

13.1 Incident Response Guidance

- Isolate the infected endpoint immediately to prevent lateral movement and data exfiltration via the active C2 channel.
- Run Calamine (FireEye's ChopShop + PyCommand) against captured memory images to extract operator passwords, mutex values, C2 configuration, and decrypted data.
- Review HKCU and HKLM Run registry keys for unauthorized persistence entries.
- Enumerate all NTFS Alternate Data Streams on the system using Streams.exe or forensic tools to find hidden PIVY server binaries.
- Hunt for svchost.exe or other system process instances with injected foreign DLLs using EDR memory analysis.
- Capture and analyze all outbound network traffic to identify Camellia-encrypted beacons and enumerate unique C2 domains for threat intelligence enrichment.
- Review email logs for spearphishing delivery artifacts; preserve weaponized attachments for YARA scanning and sandbox detonation.

14. References and Intelligence Sources

Source	Reference
FireEye (2013)	Poison Ivy: Assessing Damage and Extracting Intelligence — Primary research report analyzing 194 PIVY samples (2008-2013). Source of Calamine toolset.

Source	Reference
Proofpoint (2019)	Operation LagTime IT: Chinese APT Uses Poison Ivy Malware to Target Government — TA428 attribution and PIVY/Cotx overlap analysis.
F-Secure	Backdoor:W32/PoisonIvy — Technical description of PIVY server behaviour, persistence, and ADS usage.
NJCCIC Advisory	Poison Ivy Trojan advisory — Campaign timeline including Nitro (2011), Java zero-day (2012), IE zero-day (2013).
Volatility Labs (2012)	Reverse Engineering Poison Ivy's Injected Code Fragments — Deep-dive into PIVY code injection, Camellia key scheduling, and anti-disassembly techniques.
SecurityWeek (2017)	Poison Ivy RAT Campaign Leverages New Delivery Techniques — Documentation of AppLocker bypass, fileless execution, Regsvr32/SCT delivery methods.
The Register (2013)	Poison Ivy RAT becoming the AK-47 of cyber-espionage attacks — Molerats campaign and broader China-nexus actor adoption documented.
OASIS CTI STIX2	cti-stix2-json-schemas/poisonivy.json — Structured STIX 2.0 representation of PIVY threat intelligence including actor profiles and C2 IOCs.
Huntress (2025)	Poison Ivy Malware: Analysis, Detection, Removal — Updated threat library entry with MITRE ATT&CK mappings and current detection guidance.

15. New Activity Timeline and Behavioural Changes

This section tracks the evolution of Poison Ivy's deployment techniques, operator adaptations, and newly observed campaign activity. Changes in TTP, delivery method, or infrastructure signal actor maturity and inform detection re-tuning.

Period	Change / New Activity	Behavioural Detail	Detection Impact
2005–2010	Initial deployment; default configuration widely used	Most samples used default password 'admin' and port 3460; minimal customization observed	High detectability; default IOCs broadly shared
2011–2012	Shift to zero-day delivery	Nitro campaign integrated Java zero-day (2012) and Flash zero-day (RSA breach 2011) as delivery mechanisms, elevating PIVY beyond script-kiddie use	Zero-day delivery bypassed signature-based detection at time of deployment
2013	Watering-hole pivot by th3bug	th3bug adopted strategic web compromise over spearphishing, indicating operational sophistication and shift toward less targeted but broader victim pool	Network-layer detection needed; endpoint indicators insufficient alone

Period	Change / New Activity	Behavioural Detail	Detection Impact
2013	Certificate abuse (Molerats)	Molerats signed PIVY payload with fraudulent Microsoft code-signing certificate — first documented use of cert abuse in PIVY campaigns	Trust-based controls (Authenticode) bypassed; hash-based detection still effective
2017 (Feb)	AppLocker bypass + fileless execution (Mongolian govt campaign)	New campaign used Regsvr32.exe with remote SCT file to bypass AppLocker; fileless execution reduced on-disk artifacts; macros in Word docs used for initial execution	AppLocker bypass required; memory-based detection necessary; YARA rules for SCT/Regsvr32 abuse recommended
2019+	PIVY reuse alongside custom RATs (TA428)	TA428 deployed PIVY concurrently with custom Cotx RAT via CVE-2018-0798; C2 infrastructure shared between tools — indicates PIVY used as lightweight persistence while custom tool used for primary ops	Detect via shared C2 pivot; Cotx and PIVY IOCs overlap — one detection may surface the other
2020–2026	Continued variant circulation; updated evasion wrappers	PIVY core functionality unchanged but observed wrapped in new packers and loaders to evade AV signatures. Commodity availability on underground forums continues.	Unpack and scan for PIVY core strings / Camellia marker; packer signatures alone insufficient

16. Research Notes and Evidence Table

The following table consolidates key analytical findings, source assessments, and evidentiary notes compiled during the production of this intelligence report. Each entry documents the evidence type, its source, assessed reliability, and its contribution to the overall Poison Ivy intelligence picture.

#	Evidence Type	Finding / Note	Source	Reliability	Analyst Assessment
1	Malware Sample Analysis	194 PIVY samples analyzed (2008-2013); 22 passwords, 148 mutexes, 147 domains, 165 IPs extracted	FireEye (2013)	High — primary research	Foundational dataset. Passwords and mutexes are the strongest campaign-attribution pivot points.
2	Encryption Confirmation	PIVY C2 traffic encrypted with Camellia-256; key derived from operator-set password; default 'admin'	FireEye / malware.lu APT1 report	High — independently verified	Camellia marker ('\$camellia\$') is highly reliable YARA detection string. Key cracking via Calamine is

#	Evidence Type	Finding / Note	Source	Reliability	Analyst Assessment
					operationally feasible.
3	Operator Attribution — menuPass	US DOJ 2018 indictment names Zhu Hua & Zhang Shilong as APT10 operators; linked to MSS Tianjin Bureau	US DOJ Case 18-cr-891	High — legal indictment	Highest-confidence public attribution for any PIVY-using actor. Legal record provides named operators and organizational linkage.
4	Infrastructure Analysis	admin@338 C2 resolves to 219.76.208.163; uses dynamic DNS services (dynssl.com, freetcp.com, fartit.com)	FireEye (2013)	High — sample-corroborated	Dynamic DNS use is consistent TTPs for this actor. IPs should be treated as potentially rotated; domain tracking preferred.
5	Proxy / Relay Infrastructure	APT1-linked PIVY C2 hidden behind port-forwarding proxy; MAC OUI identified as VMWare	malware.lu APT1 report (2013)	Medium — single incident	Operators actively conceal true C2 IPs. Passive DNS and BGP analysis recommended to trace infrastructure chains beyond relay layer.
6	ADS / Alternate Data Stream Usage	Some PIVY variants write server binary to NTFS ADS; invisible to standard dir listings	F-Secure Backdoor:W32/PoisonIvy	High — vendor-verified	ADS scanning (Streams.exe, forensic tools) is essential during IR. Standard AV may miss ADS-resident payloads.
7	AppLocker Bypass Technique	2017 campaign used Regsvr32 + remote SCT file to bypass AppLocker; fileless execution observed	FireEye / SecurityWeek (2017)	High — documented campaign	Indicates actor monitors and adapts to enterprise defensive controls. Script-based detection and memory scanning required.

#	Evidence Type	Finding / Note	Source	Reliability	Analyst Assessment
8	TA428 C2 Infrastructure Overlap	PIVY samples used by TA428 share C2 domains with Cotx RAT campaign (Operation LagTime IT)	Proofpoint (2019)	High — infrastructure-corroborated	C2 overlap is a strong attribution signal. Blocking PIVY C2 domains may also disrupt Cotx RAT activity in the same campaign.
9	Calamine Toolset Validation	FireEye Calamine (ChopShop + PyCommand) successfully decodes PIVY network and memory artifacts	FireEye (2013) — open source tools	High — publicly released and tested	Calamine remains the primary open-source toolkit for PIVY incident response. Validate tool currency against latest PIVY variants before deployment.
10	Ongoing Circulation (2026)	PIVY variants confirmed in circulation; wrapped in updated packers; commodity availability on underground forums	Huntress (2025); current TI feeds	Medium — no single confirmed 2026 campaign	Threat remains relevant. Packer updates require continuous YARA rule maintenance. Core Camellia/mutex detection remains valid.